



# Intensive Workshop

Cybersecurity ClassNest 2024

---



# Cyber Security Team



## Deployment Phase

**01**

- Risk Assessment
- Round Robin

## On Production Phase

**02**

- Vulnerability Assessment
- Incident Response
- Presentation

- Please, attention to the workshop's activities.
- Mute your phone.
- Manage yourself and group to complete all deliverables on time.
- Can not asking for the answer from coaches.
- To avoid snacks, foods and beverages in working area.

# Day 1 Workshop

| Time        | Task                                                  |
|-------------|-------------------------------------------------------|
| 09.00-10.40 | Introduction & Ice Breaking                           |
| 10.40-10.50 | Break                                                 |
| 10.50-12.00 | Workshop<br>(Problem Selection, Security Requirement) |
| 12.00-13.00 | Lunch with TA                                         |
| 13.00-15.45 | Workshop<br>(Risk Assessment & Control)               |
| 15.45-15.55 | Break                                                 |
| 15.55-16.10 | Preparation for Round Robin                           |
| 16.10-17.00 | Round Robin<br>(8 Mins/Group)                         |

# 01

## **Evaluate the risks based on the provided information.**

1. Get the brief for risk assessment and problem.
2. Identify and present at least 5 inherent risks, ranked in order from highest to lowest.
3. Identify and present at least 3 residual risks along with their corresponding controls, ranked in order from highest to lowest.

# Risk Assessment at Day 1

## Inherent Risk (Before apply controls)

| Threat Scenarios                                                                                                                                           | Risks                                    | Impact  | Likelihood | Risk rating |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|---------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens.                 | Financial losses and system abuse        | High    | Extreme    | Extreme     |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.                         | Data breaches and reputational damage    | Extreme | High       | Extreme     |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.                            | Accounts could be compromised            | Medium  | Extreme    | High        |
| 4. The attacker might intercept communication between the application and backend servers due to lack of proper encryption for data at rest or in transit. | Sensitive member data could be exposed   | High    | Medium     | High        |
| 5. The attacker might flood the system with excessive API calls due to lack of throttling mechanisms.                                                      | System performance could degrade or down | Medium  | Extreme    | High        |

## Current risk for deployment (After apply controls)

| Threat Scenarios                                                                                                                           | Risks                                 | Controls                                                                                                                                                                                                    | Impact | Likelihood | Risk rating |
|--------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens. | Financial losses and system abuse     | 1. Provide training for developers on secure API practices.<br>2. Enforce API authentication and authorization in security policies.<br>3. Implement RBAC and API gateway for access control.               | Medium | Medium     | Medium      |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.         | Data breaches and reputational damage | 1. Train staff on secure data storage and encryption techniques.<br>2. Enforce data classification and encryption policies.<br>3. Implement database encryption (e.g., AES-256) and key management systems. | Medium | Medium     | Medium      |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.            | Accounts could be compromised         | 1. Provide training on detecting suspicious activity.<br>2. Enforce account lockout after multiple failed login attempts.<br>3. Implement rate-limiting and CAPTCHA                                         | Medium | Low        | Low         |

# Risk Assessment at Day 1

- ☒ Problem Selection
- ☐ Security requirement
- ☐ Risk identification
- ☐ Control selection and re-assessment

# Example - Member Card System

**Industry:** Member Card System

**Purpose:** A system for adding and exchanging points based on gasoline purchases

**Application:** Mobile and web application

**Users:** 5,000 gas stations and 1 million registered members

1. APIs used for points calculation and redemption lack proper authentication and authorization mechanisms.
2. Sensitive member data, such as name, phone number, and points balance, is not encrypted at rest.
3. Rate-limiting and throttling are not implemented for point redemption and account login attempts.
4. The system does not conduct regular vulnerability scans or penetration testing.
5. Error messages expose sensitive system details, such as database structures or API endpoints.

# Risk Assessment at Day 1

- ☒ Problem Selection
- ☐ Security requirement
- ☐ Risk identification
- ☐ Control selection and re-assessment

# Risk Assessment at Day 1

- ☒ Problem Selection
- ☐ Security requirement
- ☐ Risk identification
- ☐ Control selection and re-assessment

# Security Requirements

| Security Requirements                                                                                                     | Comply/Not Comply<br>(Yes/No/NA) |
|---------------------------------------------------------------------------------------------------------------------------|----------------------------------|
| 1. All Production, Testing, and Development environments must be segregated.                                              |                                  |
| 2. Web Server, Application, and Database servers must be hosted in separate tiers with limited access.                    |                                  |
| 3. The internet-facing application, including mobile applications, must be protected by a Web Application Firewall (WAF). |                                  |
| 4. Ensure secure communication by using TLS 1.2 or higher for all data transmissions.                                     |                                  |
| 5. All user credentials must be securely stored using industry-standard encryption (e.g., bcrypt, PBKDF2).                |                                  |
| 6. Implement strong password policies, including minimum length, complexity, and expiration.                              |                                  |
| 7. Multi-Factor Authentication (MFA) must be enforced for all user accounts with access to sensitive information.         |                                  |
| 8. All third-party libraries and dependencies must be reviewed for vulnerabilities and updated regularly.                 |                                  |
| 9. Ensure all APIs implement proper authentication and authorization mechanisms.                                          |                                  |
| 10. Implement input validation and output encoding to prevent injection attacks.                                          |                                  |
| 11. Session management must include secure cookies and proper timeout mechanisms.                                         |                                  |
| 12. Ensure that error messages do not expose sensitive information.                                                       |                                  |
| 13. Implement logging and monitoring for all critical actions, such as login attempts and data modifications.             |                                  |
| 14. Security patches must be applied promptly based on the criticality of the vulnerability.                              |                                  |
| 15. Regular vulnerability scans and penetration testing must be conducted for the application.                            |                                  |
| 16. Data must be classified and protected based on its sensitivity level.                                                 |                                  |
| 17. Ensure access control follows the principle of least privilege for all roles and users.                               |                                  |
| 18. Backups must be encrypted and regularly tested for restoration.                                                       |                                  |
| 19. Implement DDoS protection mechanisms for publicly accessible services.                                                |                                  |
| 20. Ensure audit trails are tamper-proof and stored securely for a predefined retention period.                           |                                  |
| 21. Use a Secure Software Development Lifecycle (SSDLC) approach to integrate security into the development process.      |                                  |
| 22. Implement rate-limiting and throttling to prevent abuse of APIs and endpoints.                                        |                                  |
| 23. Ensure logging does not include sensitive data such as passwords or personal identifiers.                             |                                  |
| 24. Protect administrative interfaces with IP whitelisting or additional authentication layers.                           |                                  |
| 25. Ensure no hard-coded credentials exist in source code or configuration files.                                         |                                  |
| 26. Sensitive data in transit and at rest must be encrypted using industry standards.                                     |                                  |
| 27. Ensure that all system configurations follow security baselines and are regularly audited.                            |                                  |
| 28. All unused services, ports, and protocols must be disabled.                                                           |                                  |
| 29. Regularly review and update all access permissions for systems and applications.                                      |                                  |
| 30. Ensure all critical data flows are mapped and documented for security review.                                         |                                  |

# Risk Assessment at Day 1

- ☒ Problem Selection
- ☒ Security requirement
- ☐ Risk identification
- ☐ Control selection and re-assessment

# Risk Assessment at Day 1

## Inherent Risk (Before apply controls)

| Threat Scenarios                                                                                                                                           | Risks                                    | Impact | Likelihood | Risk rating |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|--------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens.                 | Financial losses and system abuse        |        |            |             |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.                         | Data breaches and reputational damage    |        |            |             |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.                            | Accounts could be compromised            |        |            |             |
| 4. The attacker might intercept communication between the application and backend servers due to lack of proper encryption for data at rest or in transit. | Sensitive member data could be exposed   |        |            |             |
| 5. The attacker might flood the system with excessive API calls due to lack of throttling mechanisms.                                                      | System performance could degrade or down |        |            |             |

## Current risk for deployment (After apply controls)

| Threat Scenarios | Risks | Controls | Impact | Likelihood | Risk rating |
|------------------|-------|----------|--------|------------|-------------|
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |

# Risk Assessment at Day 1

- ☒ Problem Selection
- ☒ Security requirement
- ☐ Risk identification
- ☐ Control selection and re-assessment

# Risk Assessment at Day 1

## Inherent Risk (Before apply controls)

| Threat Scenarios                                                                                                                                           | Risks                                    | Impact | Likelihood | Risk rating |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|--------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens.                 | Financial losses and system abuse        |        |            |             |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.                         | Data breaches and reputational damage    |        |            |             |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.                            | Accounts could be compromised            |        |            |             |
| 4. The attacker might intercept communication between the application and backend servers due to lack of proper encryption for data at rest or in transit. | Sensitive member data could be exposed   |        |            |             |
| 5. The attacker might flood the system with excessive API calls due to lack of throttling mechanisms.                                                      | System performance could degrade or down |        |            |             |

## Current risk for deployment (After apply controls)

| Threat Scenarios | Risks | Controls | Impact | Likelihood | Risk rating |
|------------------|-------|----------|--------|------------|-------------|
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |

# Risk Matrix

Impact

|         | Risk Rating Matrix |        |         |         |
|---------|--------------------|--------|---------|---------|
| Extreme | Medium             | High   | Extreme | Extreme |
| High    | Medium             | High   | High    | Extreme |
| Medium  | Low                | Medium | High    | High    |
| Low     | Low                | Low    | Medium  | Medium  |
|         | Low                | Medium | High    | Extreme |

Likelihood

# How to measure the Business Impact and Likelihood

| ผลกระทบต่อองค์กร                    | ความเสียหาย                                          |                                                               |                                                                                    |                                                                                    |                                                                          |                                              |                                                                                                            |
|-------------------------------------|------------------------------------------------------|---------------------------------------------------------------|------------------------------------------------------------------------------------|------------------------------------------------------------------------------------|--------------------------------------------------------------------------|----------------------------------------------|------------------------------------------------------------------------------------------------------------|
|                                     | Customer                                             | Finance (THB)                                                 | Compliance                                                                         | Reputation                                                                         | Employee                                                                 | IT System                                    | Continuity                                                                                                 |
| <b>สูงมาก (Extreme)</b><br><b>4</b> | มีผลกระทบกับลูกค้าเกือบทุกคน                         | กระทบกับรายได้จนอาจมีผลให้บริษัทขาดทุน                        | ถูกลงโทษจากทางการในระดับรุนแรง เช่น เพิกถอนใบอนุญาตดำเนินการ หรือถูกดำเนินคดีจำคุก | เป็นข่าวดังระดับโลก                                                                | บุคลากรเสียชีวิตหลายคน                                                   | เกิดความเสียหายต่อระบบ IT ทั้งหมด            | ไม่สามารถกู้คืนระบบได้ภายในเวลา ต้องมีการหยุดการให้บริการ และ ไม่สามารถทดแทนให้บริการแบบ manual ได้        |
| <b>สูง (High)</b><br><b>3</b>       | มีผลกระทบกับลูกค้าจำนวนมาก                           | กระทบกับรายได้ แต่ไม่ถึงกับทำให้บริษัทขาดทุน                  | ถูกลงโทษจากทางการ เช่น ระงับใบอนุญาตหรือถูกปรับเงิน                                | เป็นข่าวดังระดับประเทศ ออกรายการดัง เช่น เรื่องเล่าเช้านี้ หรือ โทนกระแส           | บุคลากรเสียชีวิต                                                         | เกิดความเสียหายต่อระบบ IT ส่วนมาก            | ไม่สามารถกู้คืนระบบได้ภายในเวลา อาจจะมีการหยุดการให้บริการบางส่วน แต่สามารถทดแทนการให้บริการแบบ manual ได้ |
| <b>ปานกลาง (Medium)</b><br><b>2</b> | มีผลกระทบลูกค้าบางส่วน                               | กระทบกับรายได้บางส่วน                                         | ถูกตักเตือนจากทางการ                                                               | เป็นข่าวในประเทศ ออกข่าวสั้น ลงข่าวในหนังสือพิมพ์ หรือ ขึ้นเทรนด์บน X, หรือ Tiktok | บุคลากรได้รับบาดเจ็บ การ admit หรือต้องได้รับการรักษาจากสถานพยาบาล       | เกิดความเสียหายต่อระบบ IT บางส่วน            | สามารถกู้คืนระบบได้ภายในเวลาอันสั้น หรือสามารถทดแทนการให้บริการแบบ manual ได้ทันที                         |
| <b>น้อย (Low)</b><br><b>1</b>       | มีผลกระทบลูกค้าส่วนน้อย หรือไม่มีผลกระทบต่อลูกค้าเลย | มีผลกระทบกับรายได้เล็กน้อย หรือไม่มีผลกระทบต่อรายได้บริษัทเลย | ไม่มีผลกระทบ                                                                       | มีการเขียนบทความหรือ post ข้อมูลข่าวออนไลน์                                        | บุคลากรได้รับบาดเจ็บเล็กน้อย ไม่มีการ admit หรือสามารถรักษาตัวได้ที่บ้าน | ไม่เกิดความเสียหายต่อระบบ IT หรือเสียหายน้อย | สามารถกู้คืนระบบได้ภายในเวลาอันสั้น                                                                        |

| Likelihood Rating | Meaning                                             |
|-------------------|-----------------------------------------------------|
| Extreme (4)       | Once or more per year                               |
| High (3)          | Between once or more per year and once per 10 years |
| Medium (2)        | Between one per 10 years and once per 30 years      |
| Low (1)           | Less than once per 30 years                         |

# Risk Matrix

## Example 1:

**Threat scenarios:** The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens.

**Risk:** Financial losses and system abuse

**Impact:** High >> Financial loss

**Likelihood:** Extreme >> Once per year

**Risk:** High x Extreme = Extreme

**Impact**

|         | Risk Rating Matrix |        |         |         |
|---------|--------------------|--------|---------|---------|
| Extreme | Medium             | High   | Extreme | Extreme |
| High    | Medium             | High   | High    | Extreme |
| Medium  | Low                | Medium | High    | High    |
| Low     | Low                | Low    | Medium  | Medium  |
|         | Low                | Medium | High    | Extreme |

**Likelihood**

# Risk Assessment at Day 1

## Inherent Risk (Before apply controls)

| Threat Scenarios                                                                                                                                           | Risks                                    | Impact  | Likelihood | Risk rating |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|---------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens.                 | Financial losses and system abuse        | High    | Extreme    | Extreme     |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.                         | Data breaches and reputational damage    | Extreme | High       | Extreme     |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.                            | Accounts could be compromised            | Medium  | Extreme    | High        |
| 4. The attacker might intercept communication between the application and backend servers due to lack of proper encryption for data at rest or in transit. | Sensitive member data could be exposed   | High    | Medium     | High        |
| 5. The attacker might flood the system with excessive API calls due to lack of throttling mechanisms.                                                      | System performance could degrade or down | Medium  | Extreme    | High        |

## Current risk for deployment (After apply controls)

| Threat Scenarios | Risks | Controls | Impact | Likelihood | Risk rating |
|------------------|-------|----------|--------|------------|-------------|
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |

# Risk Assessment at Day 1

-  Problem Selection
-  Security requirement
-  Risk identification
-  Control selection and re-assessment

# Risk Assessment at Day 1

## Inherent Risk (Before apply controls)

| Threat Scenarios                                                                                                                                           | Risks                                    | Impact  | Likelihood | Risk rating |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|---------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens.                 | Financial losses and system abuse        | High    | Extreme    | Extreme     |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.                         | Data breaches and reputational damage    | Extreme | High       | Extreme     |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.                            | Accounts could be compromised            | Medium  | Extreme    | High        |
| 4. The attacker might intercept communication between the application and backend servers due to lack of proper encryption for data at rest or in transit. | Sensitive member data could be exposed   | High    | Medium     | High        |
| 5. The attacker might flood the system with excessive API calls due to lack of throttling mechanisms.                                                      | System performance could degrade or down | Medium  | Extreme    | High        |

## Current risk for deployment (After apply controls)

| Threat Scenarios                                                                                                                           | Risks                                 | Controls | Impact | Likelihood | Risk rating |
|--------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|----------|--------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens. | Financial losses and system abuse     |          |        |            |             |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.         | Data breaches and reputational damage |          |        |            |             |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.            | Accounts could be compromised         |          |        |            |             |

# Risk Assessment at Day 1

## Inherent Risk (Before apply controls)

| Threat Scenarios                                                                                                                                           | Risks                                    | Impact  | Likelihood | Risk rating |
|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------|---------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens.                 | Financial losses and system abuse        | High    | Extreme    | Extreme     |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.                         | Data breaches and reputational damage    | Extreme | High       | Extreme     |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.                            | Accounts could be compromised            | Medium  | Extreme    | High        |
| 4. The attacker might intercept communication between the application and backend servers due to lack of proper encryption for data at rest or in transit. | Sensitive member data could be exposed   | High    | Medium     | High        |
| 5. The attacker might flood the system with excessive API calls due to lack of throttling mechanisms.                                                      | System performance could degrade or down | Medium  | Extreme    | High        |

## Current risk for deployment (After apply controls)

| Threat Scenarios                                                                                                                           | Risks                                 | Controls                                                                                                                                                                                                    | Impact | Likelihood | Risk rating |
|--------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------|------------|-------------|
| 1. The attacker might use API endpoints for points calculation and redemption without providing valid credentials or authorization tokens. | Financial losses and system abuse     | 1. Provide training for developers on secure API practices.<br>2. Enforce API authentication and authorization in security policies.<br>3. Implement RBAC and API gateway for access control.               | Medium | Medium     | Medium      |
| 2. An attacker might exploit system vulnerabilities or obtain physical access to the database to retrieve unencrypted member data.         | Data breaches and reputational damage | 1. Train staff on secure data storage and encryption techniques.<br>2. Enforce data classification and encryption policies.<br>3. Implement database encryption (e.g., AES-256) and key management systems. | Medium | Medium     | Medium      |
| 3. The attacker might perform brute force attacks on account login APIs or abuse the points redemption functionality with bots.            | Accounts could be compromised         | 1. Provide training on detecting suspicious activity.<br>2. Enforce account lockout after multiple failed login attempts.<br>3. Implement rate-limiting and CAPTCHA                                         | Medium | Low        | Low         |

# Risk Assessment at Day 1

-  Problem Selection
-  Security requirement
-  Risk identification
-  Control selection and re-assessment

## Deployment Phase

**01**

- Risk Assessment
- Round Robin

2 Years  
Later!

## On Production Phase

**02**

- Vulnerability Assessment
- Incident Response
- Presentation

# Risk Assessment (Template)

## Inherent Risk (Before apply controls)

| Threat Scenarios | Risks | Impact | Likelihood | Risk rating |
|------------------|-------|--------|------------|-------------|
|                  |       |        |            |             |
|                  |       |        |            |             |
|                  |       |        |            |             |
|                  |       |        |            |             |
|                  |       |        |            |             |

## Current risk for deployment (After apply controls)

| Threat Scenarios | Risks | Controls | Impact | Likelihood | Risk rating |
|------------------|-------|----------|--------|------------|-------------|
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |
|                  |       |          |        |            |             |